ACCESS CONTROL PROCESS

SOP-008 | Standard Operating Procedure | Issued under POL-008

Document ID: SOP-008
Version: 1.0 — DRAFT
Parent Policy: POL-008 — Access Control Policy
Classification: Internal Use
Owner: Information Security
Co-Owner: Data Custodian (IT)
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Access Control Process
Document ID	SOP-008
Version	1.0 — DRAFT
Parent Policy	POL-008 — Access Control Policy
Related Documents	POL-005 (System Classification), POL-006 (CSV), POL-007 (Change Management), POL-009 (PAM), POL-010 (IS Risk), POL-012 (Incident Response), POL-013 (Third Party), POL-014 (Audit Trail), SOP-006 (Validation Process), SOP-007 (Change Management Process), SOP-009 (PAM Process), SOP-013 (Vendor Risk Process), EXC-001 (Exception Management)
Owner	Information Security Manager
Co-Owner	Data Custodian (IT)
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]

NOTE: This SOP governs standard user access — provisioning, modification, and deprovisioning of named individual accounts across [Company Name] systems. Privileged access (system administrator, database administrator, break-glass, and service accounts) is governed by SOP-009. Where a provisioning action would also grant privileged access, both SOPs apply and SOP-009 takes precedence on the privileged element.

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This SOP defines the end-to-end identity lifecycle process for all [Company Name] system users — from initial provisioning through role changes to final deprovisioning. It operationalises the access control requirements of POL-008 by establishing the specific steps, timelines, approval authorities, and documentation requirements for every access change event.

The process has three equal priorities: security (ensuring access is always proportionate to role and business need), regulatory compliance (ensuring GxP and SOX ITGC access requirements are met), and operational efficiency (ensuring legitimate users receive access promptly and reliably). These priorities occasionally create tension — for example, the requirement to complete GxP training before provisioning access to a GxP system may delay go-live. This SOP resolves those tensions by being explicit about the sequence and the non-negotiable steps.

2. Scope

This SOP applies to all access provisioning, modification, and deprovisioning for named individual user accounts across all [Company Name] systems — on-premises, cloud, and SaaS. It covers:

- Employee and contractor access (joiners, movers, leavers)
- Third-party user access (vendor and partner access provisioned under POL-013 / SOP-013 commercial controls)
- Temporary access (time-bounded access for specific projects or activities)
- Role-based access control (RBAC) role definitions and role assignment

Explicitly outside scope: privileged and administrator accounts (SOP-009); service and system accounts (SOP-009); guest or anonymous access to public-facing systems; access management for systems undergoing initial validation where access is provisioned as part of the IQ/OQ process (SOP-006 governs, though access controls confirmed in IQ must subsequently be maintained via this SOP).

3. Roles and Responsibilities

Role	Responsibility in This Process
Information Security Manager	Process owner. Approves access provisioning for Tier 1 and GxP systems. Oversees periodic access reviews. Escalates access anomalies detected during review.
Data Custodian (IT)	Implements approved access changes in the identity management

Role	Responsibility in This Process
	system or directly in target systems where no IAM integration exists. Confirms implementation within required timelines. Executes access deprovisioning on leaver notifications.
Line Manager	Approves access requests for their direct reports. Confirms that access requested is consistent with the employee's role and business need. Initiates leaver notifications when a direct report leaves or changes role. Certifies accuracy of access during periodic access reviews.
System Owner	Approves access requests for their system where elevated approval is required (Tier 1, GxP). Defines and maintains the RBAC role definitions for their system. Participates in periodic access review for their system.
Compliance / QA	Confirms GxP training completion before access is provisioned to any GxP system. Co-approves access to GxP systems requiring Compliance / QA sign-off. Reviews access review results for GxP systems.
HR	Authoritative source of joiner, mover, and leaver events. Issues timely notifications to Information Security and Data Custodian (IT) per the timelines in this SOP. Confirms contractor and third-party access termination dates.
DPO	Reviews access requests and access review outputs for systems with GDPR flag where access involves personal data processing. Confirms adequacy of access controls for personal data systems.

4. Joiner Process — New Access Provisioning

The joiner process governs the provisioning of access for new employees, contractors, and third-party users. Access provisioning is initiated by the Line Manager or System Owner and follows the approval and implementation sequence below.

IMPORTANT: No access may be provisioned before all mandatory pre-conditions for the target system are confirmed. The pre-conditions differ by system tier and regulatory flag. Provisional or 'temporary until training is complete' access to GxP systems is not permitted — training completion is a pre-condition, not a post-provisioning obligation.

Step 01	**Access Request Submission** The Line Manager (for employee/contractor access) or System Owner (for third-party access or direct system requests) submits an Access Request via the ITSM platform. Mandatory Access Request fields: — User name, employee/contractor ID, role title — Target system(s) and requested access role(s) — Business justification: why this access is needed for this role — Access duration: permanent (until role change or departure) or time-limited (specify end date) — For third-party users: reference to approved SOP-013 vendor assessment and DPA/BAA/Technical Agreement where applicable — Manager confirmation that Least Privilege principle has been applied — the minimum access required to perform the role, not the maximum available Requests without complete mandatory fields are returned to the requester without processing.	Responsible **Line Manager / System Owner**
Step 02	**Pre-Condition Verification** Information Security verifies that all pre-conditions for the requested access are satisfied before the approval routing step. Pre-conditions by system type: All systems: — User identity confirmed in HR system (employee/contractor record active) — No open access conflicts (user does not already hold conflicting access — SoD check) Tier 1 and Tier 2 systems additionally: — MFA enrolment confirmed in identity provider — Security awareness training completed (current year) GxP systems additionally: — System-specific GxP training completed and recorded — confirmed by Compliance / QA — Named individual account confirmed (shared/generic account requested → rejected and returned) — Access role confirmed to be in the approved RBAC role set for the system SOX ITGC systems additionally: — SoD matrix reviewed for finance roles — no SoD conflict permitted Failed pre-conditions: request placed On Hold. Requester notified with specific outstanding items. Request does not progress until all pre-conditions are satisfied.	Responsible **Information Security**
Step 03	**Approval** Approval routing is determined by the target system's tier and regulatory flags: Tier 4 and Tier 3 (no regulatory flags): — Line Manager approval is sufficient — Implementation may proceed on Line Manager approval Tier	Responsible **Line Manager / System Owner / Information Security**

	2 (no GxP or SOX flag): — Line Manager approval + Information Security review — Information Security may approve or escalate to System Owner Tier 1 and GxP systems: — Line Manager approval — System Owner approval — Information Security Manager approval — Compliance / QA confirmation of GxP training (GxP systems) — All four approvals required before provisioning proceeds SOX ITGC systems: — Line Manager approval — System Owner approval — Information Security Manager approval (SoD check confirmed) All approvals are recorded in the ITSM platform with approver identity and timestamp. Verbal or email approvals outside the ITSM platform are not valid.	**Manager / Compliance QA**
Step 04	**Implementation** Data Custodian (IT) implements the approved access change within the required timeline: Implementation timelines (from final approval): — Tier 1 and GxP systems: within 1 business day — Tier 2 systems: within 2 business days — Tier 3/4 systems: within 5 business days Implementation is recorded as a Standard Change under SOP-007 (standard user provisioning is a pre-approved Standard change procedure). On implementation: — Access confirmed in target system against the approved role specification — MFA confirmed active for Tier 1/2 users (system will not permit access without MFA) — For GxP systems: audit trail entry for access provisioning confirmed — user identity, timestamp, and access role recorded in the system audit trail — Implementation confirmation sent to Line Manager and user If implementation cannot be completed within the timeline: Information Security Manager notified with reason and revised timeline.	Responsible **Data Custodian (IT)**
Step 05	**Access Record Update** On confirmed implementation: — Access Register (or IAM system record) updated: user, system, access role, approval reference, provisioning date, scheduled review date — For GxP systems: VMF access record updated (Section 11 of VMF structure per SOP-006) — For SOX systems: access provisioning evidence filed for ITGC audit trail — For time-limited access: expiry date recorded; automated reminder set for 5 business days before expiry ITSM ticket closed with implementation confirmation.	Responsible **Data Custodian (IT) / Information Security**

5. Mover Process — Access Modification on Role Change

The mover process governs access changes when an existing user changes role — through promotion, lateral move, secondment, or significant change in responsibilities. The key risk in the mover process is access accumulation: a user who moves roles retains their previous access plus gains new access, resulting in a profile that no longer reflects least privilege. This SOP mandates an explicit delta assessment at every role change.

Step 01	**Role Change Notification** HR issues a Role Change Notification to Information Security and the user's new and previous Line Managers on the effective date of the role change — not after the fact. Notification must include: — User name and employee ID — Previous role and new role — Effective date of change — Whether the change involves a change of Line Manager — Whether the new role is in a different business unit (increases the likelihood of access profile incompatibility) For promotions within the same team where access requirements are unchanged: new Line Manager may confirm 'no access change required' in writing — Information Security records this confirmation and no further action is required.	Responsible **HR / Line Manager**
Step 02	**Access Delta Assessment** Information Security, working with the new Line Manager and System Owner, produces an Access Delta Assessment covering: — Access to revoke: all access from previous role that is not required in the new role (previous role access is revoked by default unless explicitly retained) — Access to add: new access required for the new role (follows Joiner process for each new system) — Access to retain: access that is required in both roles — explicitly confirmed, not assumed The access delta assessment must be completed within 3 business days of the role change effective date. Pending completion, the user operates with their existing access profile — new access is not provisioned until the delta assessment is approved.	Responsible **Information Security / New Line Manager**
Step 03	**Approval and Implementation** Access revocations are implemented immediately on Line Manager approval — no further approval required (removing access is always lower risk than granting it). Access additions follow the Joiner Process (Section 4) — pre-conditions, approval routing, and implementation timelines apply. Implementation timelines for access revocations: — Tier 1 and GxP systems: within 1 business day of approval — Tier 2: within 2 business days — Tier 3/4: within 5 business days On completion of all revocations and additions: new Line Manager confirms access profile is correct. Confirmation recorded in ITSM. Access Register updated.	Responsible **Data Custodian (IT) / Information Security**

6. Leaver Process — Access Deprovisioning

The leaver process is the highest-risk identity lifecycle event. A former employee, contractor, or third-party user retaining active access after departure is an immediate security and compliance risk. The timelines in this section are non-negotiable — they reflect regulatory requirements (GxP, SOX ITGC) and the risk profile of continued access after the employment or engagement relationship has ended.

NOTE: Immediate suspension (Step 2 below) and full deprovisioning (Step 3) are separate steps for

a reason: suspension is a rapid security measure; full deprovisioning is a deliberate, confirmed process. Do not skip suspension in favour of 'we'll do the full deprovision now' — the risk of a missed account is higher when proceeding directly to full removal without the suspension safety net.

Step 01	**Leaver Notification** HR issues a Leaver Notification to Information Security and Data Custodian (IT) on the same day that the decision to terminate the employment or engagement is confirmed — not on the last day of employment. Notification must include: — User name and employee/contractor ID — Last day of access (not necessarily the same as last day of employment — access may need to end earlier for sensitive departures) — Departure type: voluntary resignation / involuntary termination / contract end / redundancy — Flag if the individual had privileged access (SOP-009 parallel process triggered) — Flag if the individual had GxP system access — Flag if the individual had SOX ITGC system access For involuntary terminations and departures where the departure is not amicable: Information Security Manager is notified immediately (same day) and access suspension is immediate rather than on the last day of access.	Responsible **HR**
Step 02	**Access Suspension — Within 24 Hours of Last Day of Access** Data Custodian (IT) suspends (disables, not deletes) all accounts for the departing individual within 24 hours of the last day of access: — Corporate identity provider account: disabled (blocks SSO to all federated systems) — Email account: disabled and mail flow redirected per manager instruction — VPN and remote access: revoked immediately — MFA enrolment: deactivated — Physical access (if applicable): badge deactivated For involuntary terminations: all of the above are completed at the time of notification — not at end of day. Line Manager confirms individual is no longer on premises before badge deactivation is delayed for operational reasons. Suspension is distinct from deletion — suspended accounts are preserved for 30 days to allow: — Investigation if a security concern is identified post-departure — GxP audit trail continuity (suspended accounts are still attributed in historical records) — Data recovery if required by Line Manager within the 30-day window Suspension confirmation sent to HR and Line Manager. Information Security records suspension timestamp.	Responsible **Data Custodian (IT)**
Step 03	**Full Deprovisioning — Within 5 Business Days** Within 5 business days of the last day of access, Data Custodian (IT) completes full deprovisioning: 1. System-by-system access removal: all systems identified in the Access Register for this user. Access Register used as the checklist — if the register is incomplete, the gap is itself a finding. 2. Each access removal confirmed in the target system — not assumed from SSO deactivation alone (SSO deactivation does not revoke directly-provisioned access that predates or bypasses SSO) 3. Service accounts owned by the departing individual: ownership transferred per SOP-009 before account is closed 4. For GxP systems: audit trail entry confirming access removal recorded. VMF access record updated. 5. For	Responsible **Data Custodian (IT) / Information Security**

	SOX systems: deprovisioning evidence filed for ITGC audit trail record 6. Shared drive and data ownership transferred to Line Manager 7. License reclaim: software licences released within 30 days Deprovisioning Checklist completed in ITSM platform — one row per system with confirmation timestamp. Line Manager signs off that deprovisioning is complete. ITSM ticket closed.	
Step 04	**Account Deletion — After 30-Day Retention Window** After 30 days from suspension date (extended to 90 days for GxP systems where audit trail records must remain attributed and accessible): — Corporate identity account: deleted from identity provider — Remaining system accounts not already removed: deleted — For GxP systems: account record retained in system for audit trail attribution even after active account is deleted — confirm with Data Custodian (IT) that historical audit trail records remain attributed to the former user identity after account deletion Deletion recorded in ITSM. Access Register updated: status 'Deprovisioned', deletion date recorded.	Responsible **Data Custodian (IT)**

7. Third-Party Access

Third-party access — vendor, partner, contractor, and consultant access — follows the same joiner/mover/leaver lifecycle as employee access, with additional controls reflecting the higher risk of external access. The commercial framework (DPA, BAA, Technical Agreement, Right to Audit) governing the third-party relationship is established via SOP-013 before any access is provisioned under this SOP.

Control	Requirement	Tier A Vendor (Tier 1 / GxP access)	Tier B Vendor (Tier 2 / SOX)	Tier C Vendor (Tier 3 access)
Named individual accounts	Each vendor user must have a named individual account. No shared or generic accounts.	Mandatory — rejection of any shared account request	Mandatory	Mandatory
Access scope	Restricted to the specific systems and functions required for the engagement — not broad system access.	Named system and function list in Technical Agreement or access request	Named system list in access request	Named system list
Access duration	Time-limited to the engagement period — not open-ended.	Maximum 90 days per access grant, renewable with re-approval	Maximum 6 months, renewable	Duration of contract
Persistent access	Standing access between engagement activities is prohibited for Tier 1 and GxP systems.	JIT access per SOP-009 — access activated per maintenance window, deactivated after	Access suspended between active engagement periods	Persistent permitted
Session supervision	All sessions supervised or recorded.	Real-time supervision or PAM session recording mandatory (SOP-009)	Session recording where available	Not required

Control	Requirement	Tier A Vendor (Tier 1 / GxP access)	Tier B Vendor (Tier 2 / SOX)	Tier C Vendor (Tier 3 access)
GxP access pre-conditions	GxP training equivalent confirmed before access.	Vendor user training records confirmed by Compliance / QA	N/A (not GxP systems)	N/A
Access review	Access reviewed at engagement milestone or maximum period.	Monthly review of active third-party access list	Quarterly	At contract renewal

IMPORTANT: Third-party access must be suspended immediately on any of: engagement completion, vendor contract termination, vendor security incident (POL-013 trigger), regulatory inspection finding related to the vendor, or vendor offboarding per SOP-013. Suspension does not wait for the formal leaver process — it is immediate.

8. Periodic Access Review

Periodic access reviews confirm that all active access remains current, appropriate, and consistent with the least privilege principle. Access reviews are a regulatory obligation for GxP and SOX ITGC systems — the absence of documented access review evidence is a common inspection finding.

System Type	Review Frequency	Reviewer	Review Scope	Evidence Required
Tier 1 / GxP	Monthly	System Owner + Information Security Manager	All active accounts. Role assignments verified against current HR role. Dormant accounts (no login for 30 days) flagged for removal. Privileged accounts reviewed under SOP-009.	Signed access review record per system. Exported account list from authoritative system source (not cached list). Remediation actions recorded in ITSM. GxP: review record filed in VMF.
SOX ITGC	Quarterly	System Owner + Information Security Manager	All active accounts on SOX-scoped systems. SoD	Signed access review record. SoD conflict log

System Type	Review Frequency	Reviewer	Review Scope	Evidence Required
		+ Finance Controller	conflicts identified and resolved. Finance role access verified against approved role matrix.	with resolution evidence. Retained 7 years per POL-002.
Tier 2 (non-SOX)	Quarterly	System Owner + Information Security	All active accounts. Dormant accounts (no login for 60 days) flagged.	Signed access review record per system.
Tier 3 / 4	Annually	System Owner	All active accounts. Role appropriateness confirmed by Line Manager.	Access review confirmation per system. Remediation actions recorded.
Third-party users (Tier A/B vendors)	Monthly (Tier A) / Quarterly (Tier B)	Information Security Manager + relevant System Owner	All active third-party accounts. Engagement status confirmed. Access scope confirmed against current contract.	Third-party access review record. Engagement status confirmation from relationship owner.

8.1 Review Execution

Access reviews are conducted against an authoritative export from the target system — not a cached list or the Access Register alone. The register is verified against the system export, not the other way around. Discrepancies between the register and the system export are access anomalies and must be investigated.

Review steps:

- Export active account list from each in-scope system (Data Custodian IT)
- For each account: confirm user is still employed/engaged, confirm role is still current, confirm access scope is appropriate for current role
- Flag for removal: leavers not yet deprovisioned (immediate action), dormant accounts, role mismatches, SoD conflicts
- Remediation actions raised as ITSM tickets — each with a named owner and target date
- Reviewer signs the access review record confirming completion and accuracy
- Information Security Manager countersigns for Tier 1, GxP, and SOX reviews

8.2 Dormant Account Handling

System Type	Dormant Threshold	Action
Tier 1 / GxP	30 days without login	Automatic disable. Information Security and Line Manager notified. Re-activation requires Line Manager justification and Information Security approval.
Tier 2	60 days without login	Flag in access review. Line Manager confirms ongoing need or account disabled.
Tier 3/4	90 days without login	Flag in annual review. Account disabled if no justification provided within 10 business days.
Service accounts	No login activity expected	Governed by SOP-009 — anomalous login activity is a security alert, not a dormancy threshold.

9. Segregation of Duties

Segregation of duties (SoD) controls prevent a single individual from having sufficient access to both initiate and approve a sensitive transaction — a key fraud prevention control for SOX and a data integrity control for GxP.

Conflict Type	Systems Affected	Control
Financial SoD: Accounts Payable creation + Accounts Payable approval	SOX ITGC financial systems	No individual may hold both roles. Conflict detected during access review and at provisioning. Conflict resolution requires Finance Controller approval with documented compensating control.
GxP SoD: Data entry + Data approval	GxP systems with electronic approval workflows	Reviewer/approver role must be assigned to a different individual than the data entry role. Enforced in system configuration where technically possible; confirmed in OQ.
IT SoD: Change implementation + Change approval	All systems	The individual implementing a change may not be the sole approver of that change. Enforced through SOP-007 CAB process.
Access administration SoD: Access provisioning + Access approval	All systems	Data Custodian (IT) implements access but does not approve access requests. Line Manager approves but does not implement. Separation enforced through ITSM workflow.
Audit trail SoD: System use + Audit trail modification	GxP, Tier 1 systems	No user — including system administrators — may modify audit trail records. Technical control (immutability) is the primary control; access control is a defence-in-depth layer per POL-014.

10. Related Documents

Document ID	Title	Relationship
POL-008	Access Control Policy	Parent policy — this SOP operationalises POL-008
POL-005	System Classification Policy	System tier and regulatory flags determine approval authority, review frequency, and pre-conditions for access provisioning
POL-006	Computer System Validation Policy	GxP system access provisioning must not precede training confirmation; access changes to GxP systems are Standard changes via SOP-007 with VMF documentation
POL-007	Change Management Policy	Access provisioning, modification, and deprovisioning are implemented as Standard changes under SOP-007; access changes to Tier 1/GxP systems are recorded as change events
POL-009	Privileged Access Management Policy	SOP-009 governs all privileged accounts; where an access request includes privileged elements, SOP-009 takes precedence on the privileged component
POL-010	Information Security Risk Policy	Access anomalies detected during access review that indicate systemic risk are escalated to the IS Risk Register
POL-012	Incident Response Policy	Compromised accounts and unauthorised access events are security incidents under POL-012; SOP-008 leaver process is triggered immediately on account compromise confirmation
POL-013	Third Party and Vendor Risk Policy	Commercial framework for third-party access is established via SOP-013 before access is provisioned under this SOP; vendor offboarding per SOP-013 triggers immediate access suspension
POL-014	Audit Trail and Monitoring Policy	Access provisioning and deprovisioning events are recorded in the system audit trail; access review records are retained per POL-014 retention requirements
SOP-006	Computer System Validation Process	GxP system access is a validated configuration element — access changes require VMF documentation per SOP-006 Section 6.1
SOP-007	Change Management Process	Access changes implemented as Standard changes under SOP-007; privileged access changes are Normal changes minimum
SOP-009	Privileged Access Management	Companion SOP for privileged access —

Document ID	Title	Relationship
	Process	governs elements outside scope of this SOP
SOP-013	Third Party and Vendor Risk Assessment Process	Vendor access commercial pre-conditions established via SOP-013 before access provisioning under this SOP
EXC-001	Exception Management Policy and Register	Access control exceptions (MFA, provisioning timeline) governed by EXC-001; shared accounts on GxP systems are non-approvable per EXC-001 Section 5; 3-month maximum exception duration
RACI-001	Roles, Responsibilities and Authorities	Accountability for access control governance

11. Definitions

Term	Definition
Access Register	The authoritative record of all user accounts and their access rights across [Company Name] systems. Maintained by Data Custodian (IT) and verified against system exports during periodic access reviews.
Dormant Account	A user account that has not had any login activity for the threshold period defined by system tier (30/60/90 days). Subject to automated or review-triggered disablement.
Identity Provider	The central authentication system (e.g., Azure AD, Okta) through which SSO-federated access to connected systems is managed.
JIT Access	Just-in-time access — time-bounded, session-specific privileged access issued on demand rather than as standing access. Governed by SOP-009.
Least Privilege	The principle that a user should have the minimum access rights necessary to perform their role — no more.
Leaver	Any individual whose employment, contract, or engagement with [Company Name] ends, resulting in the deprovisioning of their system access.
Mover	Any individual who changes role within [Company Name], triggering an access delta assessment and modification of their access profile.
RBAC	Role-Based Access Control — an access management approach where access rights are associated with defined roles rather than individual users. Individual users are assigned to roles.
SoD	Segregation of Duties — the principle of dividing critical functions so that no single individual can both initiate and complete a sensitive or high-risk transaction.
SSO	Single Sign-On — authentication through a central identity provider that

Term	Definition
	grants access to federated systems without separate login.

— End of Document —

SOP-008 v1.0 DRAFT | [Company Name] | INTERNAL USE